Einstellungen

Lernunterlage: Benutzerverwaltung, der letzte Admin, Passwort ändern und Sitzungen beenden

1 Worum es geht

Die Seite **Einstellungen** (nur Admin) bündelt, wofür man sonst ins Terminal müsste: Benutzer verwalten, das eigene Passwort ändern, den Zustand der Verbindungen zu Tuya und Blink verstehen, den Abgleich-Takt je Gerät einstellen und sehen, welche Version mit welcher Datenbank läuft.

Bereich	Endpunkt	Wer
Benutzer	GET /api/users, PUT /api/users/{id}/role, DELETE /api/users/{id}	Admin
Benutzer anlegen	POST /api/auth/register (mit Rolle)	Admin
Mein Passwort	POST /api/auth/password	jeder mit JWT
Verbindungen	GET /api/status, GET /api/blink/status	angemeldet
Abgleich	GET /api/devices, PUT /api/devices/{id}	Admin
Info	GET /api/system/info	Admin

2 Regeln der Benutzerverwaltung

Regel	Warum	Antwort
nur Admin	Rechte vergeben ist die mächtigste Aktion	401 / 403
nicht sich selbst löschen oder herabstufen	Schutz vor Aussperren, das macht ein anderer Admin	409
der letzte Admin bleibt	ohne Admin kann niemand mehr verwalten	409
ungültige Rolle	nur Admin oder User	400

Welcher Statuscode? 400 heißt „die Anfrage ist falsch“ (z. B. Rolle „Chef“). 403 heißt „du darfst das nicht“. **409 Conflict** heißt „die Anfrage ist in Ordnung, passt aber nicht zum aktuellen Zustand“: Jemand zum User machen ist erlaubt, nur nicht, wenn er der letzte Admin ist.

> Die Oberfläche sperrt Knöpfe nur zur Bequemlichkeit. Ob etwas erlaubt ist, entscheidet immer der Server.

3 Der letzte Admin

Die Prüfung „gibt es noch einen anderen Admin?“ und das Ändern danach sind zwei Schritte. Laufen zwei Anfragen genau gleichzeitig, könnten beide „ja, es gibt noch einen“ sehen, und am Ende gibt es keinen mehr. Deshalb läuft immer nur eine Änderung gleichzeitig:

```
private static readonly SemaphoreSlim AdminLock = new(1, 1);

await AdminLock.WaitAsync(cancellationToken);
try
{
    if (isAdmin && await CountAdminsAsync() <= 1) return UserChangeStatus.LastAdmin;
    // ... Rolle wechseln
}
finally { AdminLock.Release(); }
```

Altes Token: Das JWT enthält die Rolle und gilt bis zu 15 Minuten. Wer gerade herabgestuft wurde, hat also noch kurz ein Token mit „Admin“. Ein Test prüft genau das: Auch mit so einem Token lässt sich der letzte Admin nicht löschen, weil der Server in der Datenbank zählt und nicht dem Token glaubt.

4 Passwort ändern

- Das **bisherige Passwort** muss stimmen. Wer nur kurz an einem fremden, angemeldeten Rechner sitzt, kann das Passwort so nicht ändern.
- Die Regeln für das neue Passwort prüft Identity: `userManager.ChangePasswordAsync(user, alt, neu)`.
- Wer, steht im Token (`caller.GetUserId()`), nie im Body. Sonst könnte jeder das Passwort eines anderen ändern.
- **Rate Limit** wie beim Login: Mit einem gestohlenen Access Token soll niemand das alte Passwort beliebig oft durchprobieren.
- Danach sind **alle anderen Geräte abgemeldet**, z. B. ein vergessenes Tablet. Das aktuelle bleibt: Der Endpunkt liegt unter `/api/auth`, dorthin schickt der Browser das Refresh-Cookie mit, und genau dieses Token bleibt erhalten.

5 Der Fehler mit der Reuse Detection

Zur Erinnerung: Wird ein schon **widerrufenes** Refresh-Token noch einmal benutzt, hält der Server es für gestohlen und beendet vorsichtshalber **alle** Sitzungen des Benutzers (Reuse Detection).

Schritt	Erste Fassung (widerrufen)	Jetzt (löschen)
Laptop ändert Passwort	Handy-Token wird widerrufen	Handy-Token wird gelöscht
Handy meldet sich	widerrufenes Token → Reuse Detection	unbekanntes Token → 401
Folge	auch der Laptop ist abgemeldet	nur das Handy ist abgemeldet

Gefunden hat das ein Test mit zwei Sitzungen (Handy und Laptop), nicht das Ausprobieren von Hand. Lehre: Neue Funktionen immer zusammen mit den **vorhandenen** Sicherheitsmechanismen testen.

6 Verbindungen und Info

- **Verbindungen** lesen dieselben Werte wie die Status-LEDs. Es gibt keine zusätzlichen Aufrufe bei Tuya oder Blink. Jeder Zustand hat einen Satz „was heißt das, was tun?“. Bei Blink „Neu anmelden nötig“ stehen die drei Schritte mit BlinkSpike direkt auf der Seite.
- **Abgleich-Tabelle:** Takt direkt in der Tabelle ändern. Gespeichert wird über denselben Endpunkt wie beim Bearbeiten eines Geräts (`deviceToInput` gibt es nur einmal, in api/devices.ts).
- **Version und Commit:** Das .NET-SDK schreibt beim Bauen `1.0.0+<Commit>` in die Assembly (InformationalVersion). Ohne Git, z. B. im Docker-Build, fehlt der Commit.
- **Datenbank:** nur Dateiname und Größe, **nie der Pfad**: Der enthielte den Benutzernamen des Rechners, und die Seite steht vielleicht auf dem Beamer.

7 Tests

Test	prüft
Benutzerliste_nur_fuer_Admin	403 für User, Liste mit Rollen
Rolle_aendern_und_zuruecksetzen	204, ungültige Rolle 400
Sich_selbst_loeschen_oder_herabstufen_geht_nicht	409
Der_letzte_Admin_bleibt_auch_mit_altem_Token_…	409, Server zählt in der Datenbank
Geloeschter_Benutzer_kann_sich_nicht_mehr_anmelden	Löschen wirkt, zweites Löschen 404
Passwort_aendern_prueft_das_alte_und_die_Regeln	Fehler an currentPassword bzw. newPassword
Neues_Passwort_gilt_und_andere_Sitzungen_werden_beendet	Handy 401, Laptop bleibt angemeldet
Info_nennt_Umgebung_und_Datenbank_ohne_Pfad_…	kein / im Dateinamen

8 Kurzantworten für Rückfragen

Frage	Antwort
Kann ich mich aussperren?	Nein: Das eigene Konto lässt sich nicht löschen oder herabstufen, der letzte Admin bleibt.
Warum 409 und nicht 400?	Die Anfrage ist richtig, passt aber nicht zum Zustand (letzter Admin).
Was ist mit offenen Sitzungen?	Nach Passwort- oder Rollenwechsel werden sie beendet, das JWT läuft nach 15 min ab.
Warum das alte Passwort abfragen?	Damit niemand an einem fremden, angemeldeten Rechner das Passwort ändert.
Was hat die Reuse Detection damit zu tun?	Widerrufene Tokens lösen sie aus, deshalb werden sie hier gelöscht.
Woher kommt der Commit?	Aus der InformationalVersion, die das .NET-SDK beim Bauen setzt.
Warum kein Pfad zur Datenbank?	Er verriete den Benutzernamen des Rechners.

9 Merksätze

- Rechte prüft der Server, die Oberfläche blendet nur aus.
- Immer einen Admin übrig lassen, und das Prüfen und Ändern gemeinsam absichern (Sperre).
- Wer etwas tut, steht im Token, nie im Body.
- 400 falsch, 403 verboten, 409 passt nicht zum Zustand.
- Neue Funktionen zusammen mit den vorhandenen Schutzmechanismen testen (Reuse Detection).